LAB - DAY 8

Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

Services, firewall rules and captured traffic



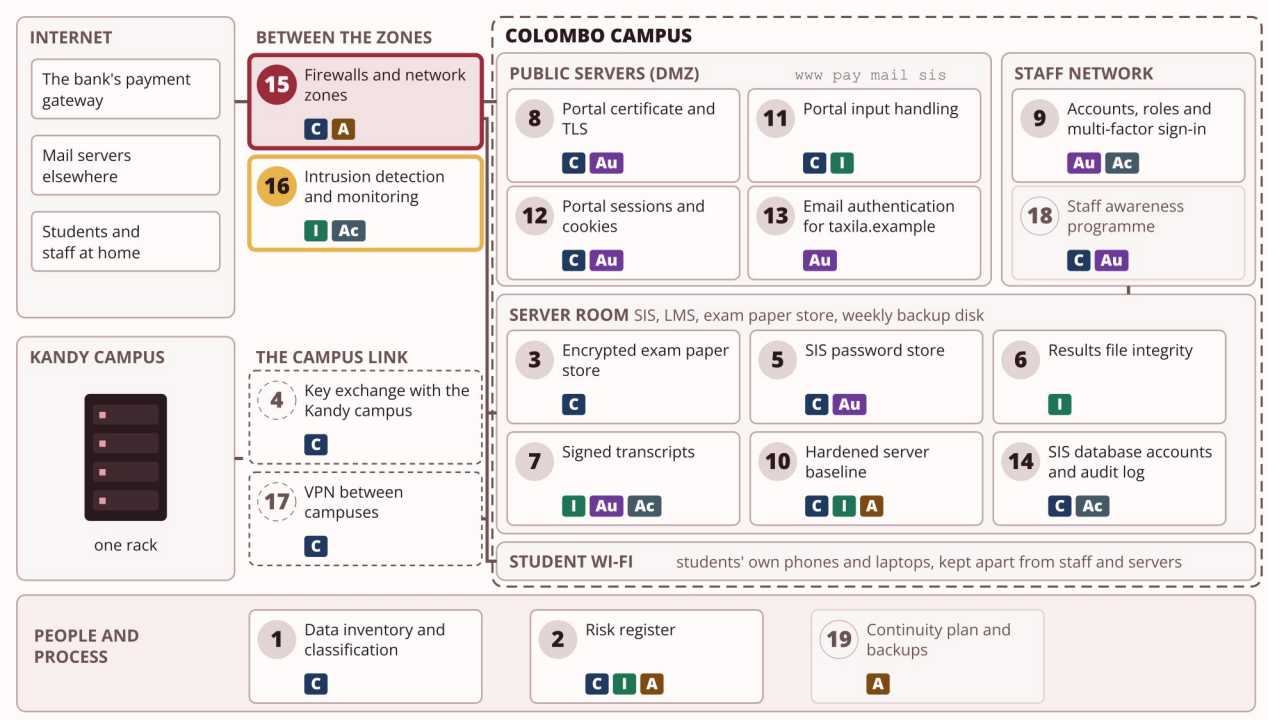
Adds to the register: **15**

Floor tier: every step

Full tier: recommended

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

The security register



TODAY

15 Firewalls and network zones

KEY

- Added today
- Added earlier
- Demonstrated
- Concept only
- Not yet added

IT

HEAD OF IT

The report says our database answers the student Wi-Fi. Tell me every door that server has, and close the worst one.

The Head of IT, at the start of the lab.

Before you start

```
# both tiers: download the provided files to your module folder
sis-services.txt  sis-outside-view.txt  firewall-rules.txt  address-traffic.pcapng
# full tier: snapshot first, then check the firewall tool
snapshot name: day-8-start
$ sudo iptables -V
iptables v1.8.x (nf_tables)
```

No evidence pack today. Keep your inventory, your rules and your address notes for your group.

SEGMENT 1 - 45 MIN

Inventory your own server's services

Both tiers

Match the server's doors, inside and out

1 Read the SIS server's own list in `sis-services.txt`.

Expected: Seven listening lines; `python3` is not a service.

Floor path: `service-doors` demo.

2 Match each port with `sis-outside-view.txt`.

Expected: `3306` open to the Wi-Fi: the highest risk.

```
PORT      STATE     WHAT ANSWERED
22/tcp    open      remote login (SSH)
3306/tcp  open      database (MariaDB)
8080/tcp  filtered  no answer
```

Port 53 is not in the outside view: it listens on the server itself only.

List your own machine's services

3

List what listens; start `apache2`; list again.

Expected: `apache2` on port `80`, on every address.

Floor path: Your inventory is steps 1 and 2.

```
$ sudo ss -tulpn
$ sudo systemctl start apache2
$ sudo ss -tulpn
tcp LISTEN 0 511 *:80 *:* users:(("apache2",...))
$ systemctl list-units --type=service --state=running
```

Running is not the same as listening. Most running services open no door at all.

SEGMENT 2 - 40 MIN

Write a firewall rule

Both tiers

Write four rules, in this order

4

Add the four rules, then list them.

Expected: REJECT port 80, ACCEPT lo, ACCEPT replies, DROP the rest.

Floor path: `firewall-rules.txt` Part A, then write your own.

```
$ sudo iptables -A INPUT -p tcp --dport 80 -j REJECT
$ sudo iptables -A INPUT -i lo -j ACCEPT
$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
$ sudo iptables -A INPUT -j DROP
$ sudo iptables -L INPUT -n -v --line-numbers
```

The test comes from the machine itself, so the port rule sits above the loopback rule.

Test both directions

5 Reload `http://127.0.0.1/`, then open an outside site.

Expected: Local page: Unable to connect. Outside site: loads.

```
$ sudo iptables -L INPUT -n -v --line-numbers
num   pkts bytes target  prot opt in  out  source     destination
1        2   120 REJECT  6    --  *   *    0.0.0.0/0  0.0.0.0/0  tcp dpt:80
3       12  2322 ACCEPT  0    --  *   *    0.0.0.0/0  0.0.0.0/0  ctstate RELATED,ESTABLISHED
```

The counters show which rule did each job.

SEGMENT 3 - 40 MIN

Capture and read address traffic

Both tiers

Capture a question and its answer

6

Capture on `eth0` with the filter `arp`; flush the cache; reload a site.

Expected: Who has 10.0.2.2? Tell 10.0.2.15, then the reply.

Floor path: `arp-trust` demo.

```
$ sudo ip neigh flush dev eth0
$ ip neigh
10.0.2.2 dev eth0 lladdr 52:54:00:12:35:02 REACHABLE
```

The field a false reply forges is the Sender MAC address.

Read a prepared false reply

7 Open `address-traffic.pcapng`; compare frames 2 and 6, then 7 and 8.

Expected: Frame 6 is marked Duplicate IP address configured.

```
1  Who has 10.10.0.1? Tell 10.10.0.21
2  10.10.0.1 is at 02:00:0a:0a:00:01
6  10.10.0.1 is at 02:00:0a:0a:00:42
7  to 10.30.0.10:443, via 02:00:0a:0a:00:42
```

Prepared for teaching: the false replies were written into the file, never sent.

SEGMENT 4 - 25 MIN

Prove it, break it, reset and write up

Both tiers

Prove it, then break it

PROVE IT

- Inventory: the listening services, with `3306` as the **highest risk**
- Full tier: `127.0.0.1` refused, an outside site still loads
- Floor tier: your rules in Part B's order

× BREAK IT

- `iptables -I INPUT 3 -j DROP`: drop-all above replies
- The outside site fails; rule 3's counter **climbs**
- Delete rule 3; replies flow again

Reset, and the rules

RESET

- Keep your notes from steps 2, 7 and 8
- Full tier: restore `day-8-start`
- Or flush the rules and stop `apache2`

RULES OF ENGAGEMENT

- No tool in this lab can affect anyone else's system
- Only your own machine and the provided files
- Poisoning is studied from a capture, never performed

Two common mistakes

```
Does rule order matter?    Yes: first match wins.
Is filtered the same       No: filtered means no
as closed?                 answer came back at all.
```

A closed port answered that nothing listens. A filtered port did not answer.

Before the next day

READ	**Security in Computing, sections 6.7 and 6.8** Firewalls and intrusion detection
PRACTICE	**Practice question 8** The courier company's tracking site
TASK	**Your group's controls map** Bring your inventory and your rules

Questions & Discussion

Next: Day 9, attacks, people, risk and continuity.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision 5a12891